CTCR
COLEGIO TÉCNICO DE COSTA RICA

FORMACIÓN INSTITUCIONAL / INFORMÁTICA

Guía de prevención y gestión de incidentes

Cómo reconocer alertas, actuar sin empeorar el problema y registrar lo sucedido.

Fundamentos de Seguridad Informática

Dirigido al personal del Departamento de Informática

Versión 1.0 · octubre de 2026 | Material de capacitación para proyecto académico

Antes de empezar

Cuando ocurre un problema de seguridad, la primera reacción suele ser intentar arreglarlo de inmediato. Sin embargo, borrar archivos, reiniciar equipos o cambiar permisos sin revisar el contexto puede dificultar la recuperación. Esta guía propone una respuesta inicial clara para el personal de Informática del colegio.

OBJETIVO DEL RECURSO

Reconocer situaciones de riesgo, aplicar una respuesta inicial ordenada y documentar los incidentes que puedan afectar los sistemas y los datos del colegio.

Contenido

01	Qué es un incidente	3
02	Detectar y priorizar señales	4
03	Primeros minutos de respuesta	5
04	Correo malicioso o phishing	6
05	Cuenta institucional comprometida	7
06	Malware o equipo sospechoso	8
07	Acceso indebido en Moodle	9
08	Registro y comunicación	10
09	Prevención, práctica y glosario	11

Guía de capacitación. Las medidas sobre equipos, redes y cuentas deben ser ejecutadas por el personal autorizado conforme al protocolo real de la institución.

1 Qué es un incidente

Un incidente de seguridad es una situación que compromete, o puede comprometer, la confidencialidad, integridad o disponibilidad de la información. Una alerta no siempre confirma un ataque; primero debe investigarse para entender qué sucedió.

Casos posibles en el CTCR

SITUACIÓN	QUÉ PODRÍA AFECTAR
Alguien abre un expediente que no le corresponde	Confidencialidad de datos personales.
Se modifican calificaciones sin autorización	Integridad de los registros.
Moodle deja de funcionar durante una evaluación	Disponibilidad del aula virtual.
Un correo suplanta a Dirección	Seguridad de cuentas y documentos.
Un equipo cifra archivos compartidos	Disponibilidad y recuperación de documentos.

No confundir incidente con mantenimiento

- Una actualización programada puede causar una interrupción normal si fue comunicada y autorizada.
- Un equipo lento no confirma malware por sí solo; requiere revisión.
- Un intento bloqueado de acceso a un curso es una señal útil de control, no necesariamente un incidente.

> **IDEA CENTRAL**
> Primero se identifica qué sistema o información está en riesgo. Luego se protege el entorno y se informa a quien pueda coordinar la respuesta.

2 Detectar y priorizar señales

La persona que atiende el reporte debe recoger datos básicos antes de actuar: qué ocurrió, cuándo comenzó, a quién afectó y si el problema sigue ocurriendo. Esto permite priorizar mejor la respuesta.

Una clasificación sencilla

PRIORIDAD	EJEMPLO	RESPUESTA INICIAL
Alta	Cuenta administrativa de Moodle utilizada sin autorización.	Aviso inmediato; acciones de contención con personal autorizado.
Media	Usuario recibió un correo falso y abrió el enlace, sin ingresar datos.	Verificación del equipo y registro del mensaje.
Baja	Mensaje sospechoso reportado y no abierto.	Registro, advertencia y prevención.

Preguntas para evaluar el alcance

01 ¿Está comprometida información personal, calificaciones, credenciales o respaldos?

02 ¿Cuántas personas o servicios podrían estar afectados?

03 ¿Hay actividad no autorizada que continúa en este momento?

04 ¿Existe riesgo de perder evidencia o de que el problema se propague?

> **ATENCIÓN**
> La prioridad real depende del impacto y los procedimientos de la institución. La tabla es una referencia didáctica, no una clasificación oficial de emergencias.

3 Primeros minutos de respuesta

Una respuesta ordenada ayuda a contener el daño y facilita la investigación. No todas las acciones aplican a todos los casos, pero sí conviene seguir la misma lógica.

Secuencia recomendada

01 **Recibir y confirmar:** escuchar el reporte, anotar la hora y verificar qué sistema presenta el problema.

02 **Reducir el riesgo:** cuando corresponda, el personal autorizado limita accesos o aísla el equipo afectado.

03 **Conservar información:** registrar mensajes, capturas, direcciones, alertas y acciones realizadas sin alterar datos innecesariamente.

04 **Escalar:** avisar al responsable técnico y, si hay datos personales, involucrar a quienes gestionan esa información.

05 **Recuperar y verificar:** corregir la causa, probar que el servicio opera y vigilar si aparecen nuevas señales.

06 **Cerrar y mejorar:** documentar qué ocurrió y qué cambiará para evitar que se repita.

> **EVITAR DECISIONES APRESURADAS**
> No formatear el equipo, borrar registros, destruir correos originales ni publicar información del caso antes de que el responsable haya evaluado el alcance.

4 Correo malicioso o phishing

Un correo que imita a Moodle, un banco o una autoridad puede pedir que se descargue un archivo o que se introduzca una contraseña. La respuesta depende de lo que hizo la persona que lo recibió.

Escenario: “Su cuenta de Moodle vencerá hoy”

QUÉ PASÓ	PRIMERA ACCIÓN
Solo recibió el mensaje	No abrir enlaces ni adjuntos; reportarlo.
Hizo clic, pero no ingresó datos	Cerrar el sitio y avisar para evaluar el equipo.
Escribió la contraseña	Notificar de inmediato; cambiar credenciales desde el sitio auténtico y revisar sesiones.
Abrió un archivo ejecutable sospechoso	Dejar de usar el equipo e informar para evaluar contención.

Datos útiles para reportar

- Remitente que aparece en el mensaje y dirección real de envío.
- Asunto, fecha y hora.
- Enlace sospechoso sin volver a abrirlo y archivos recibidos, si aplica.
- Acciones que realizó la persona antes de reportar.

> **EJEMPLO DEL COLEGIO**
> Un funcionario recibe una falsa solicitud de “verificar su correo CTCR”. Si escribió la contraseña, no basta con borrar el mensaje: es necesario proteger la cuenta y revisar el posible acceso indebido.

5 Cuenta institucional comprometida

Las alertas de inicio de sesión, cambios inesperados de contraseña o mensajes enviados sin autorización pueden indicar que otra persona accedió a una cuenta. La revisión debe hacerse de manera controlada.

Respuesta inicial

01 Verificar con la persona titular qué actividad reconoce y cuál no.

02 Comunicarlo de inmediato al responsable técnico y registrar la hora aproximada del acceso sospechoso.

03 Cuando corresponda, restablecer la contraseña desde una sesión confiable y cerrar otras sesiones activas.

04 Revisar métodos de recuperación, factores de autenticación y permisos que pudieron cambiar.

05 Comprobar si hubo envío de información, modificación de recursos o cambios de calificaciones.

06 Mantener seguimiento y comunicar al usuario las medidas de protección.

SEÑAL	DATO PARA INVESTIGAR
Se publicó un archivo sin autorización	Cuenta, hora, ubicación del archivo y registro disponible.
Aparecieron usuarios nuevos en un curso	Método de matriculación y rol asignado.
Llegaron avisos de inicio de sesión	Fecha, plataforma y sesiones reconocidas.

CUIDADO CON LAS PRUEBAS

No utilizar credenciales ajenas para investigar. Se deben usar cuentas y permisos administrativos autorizados y registrar las acciones.

6 Malware o equipo sospechoso

Cuando un equipo parece infectado, utilizarlo normalmente puede aumentar la afectación. La prioridad es reducir la posibilidad de propagación y preservar la información necesaria para investigar.

Señales de alerta

- Archivos que aparecen cifrados, cambian de extensión o no abren.
- Programas desconocidos que se ejecutan o instalan sin autorización.
- Ventanas que solicitan pagos para recuperar información.
- Conexiones o actividades del equipo que la persona no reconoce.

Qué debe hacer la persona usuaria

01	Suspender el trabajo en el equipo afectado y avisar a Informática.
02	No ejecutar programas de “limpieza” descargados de anuncios o enlaces recibidos.
03	No conectar memorias ni copiar archivos a otros dispositivos hasta recibir indicaciones.
04	Explicar qué pasó justo antes: archivo abierto, página visitada, memoria conectada o alerta observada.

Qué coordina Informática

El personal autorizado decide si corresponde desconectar el equipo de la red, preservar registros, analizar el incidente, restaurar desde copias verificadas y comprobar que la causa fue corregida.

> **NUNCA PAGAR POR INSTRUCCIONES**
>
> Ante mensajes que exigen un pago o amenazan con divulgar información, debe activarse la respuesta institucional; no negociar ni compartir datos por cuenta propia.

7 Acceso indebido en Moodle

El aula virtual contiene cursos, archivos, cuestionarios y registros de evaluación. Un error de configuración de usuarios o permisos podría mostrar recursos a personas de otro departamento.

Ejemplo práctico en el CTCR

Marta pertenece a Administración e intenta abrir el curso de Informática. Moodle debe impedir su matrícula y el acceso al contenido. Si puede abrir directamente un PDF privado aunque no vea el curso, hay que investigar la protección del recurso.

Qué revisar

01 Anotar la cuenta utilizada, el curso, la hora y la dirección del recurso donde se observó el acceso.

02 Verificar las cohortes, participantes y métodos de matriculación del curso afectado.

03 Revisar si hay acceso de invitados, matriculación abierta o roles asignados por error.

04 Comprobar si el archivo se compartió mediante un enlace público externo al curso.

05 Corregir el permiso con una cuenta autorizada y repetir la prueba con un usuario que no pertenezca al departamento.

PRUEBA	RESULTADO CORRECTO
Administración abre su propio curso	Acceso permitido.
Administración abre Docencia	Acceso denegado.
Administración abre un archivo privado de Informática	Acceso denegado.

EVIDENCIA ÚTIL

Guardar capturas del usuario de prueba, del recurso al que intentó acceder y del mensaje de Moodle. No incluir contraseñas ni datos privados en las capturas.

8 Registro y comunicación

La bitácora de incidentes permite reconstruir lo sucedido y verificar si las medidas dieron resultado. Debe conservar hechos observados y distinguirlos de hipótesis todavía no confirmadas.

Ficha de reporte inicial

CAMPO	EJEMPLO PARA CAPACITACIÓN
Fecha y hora	24/10/2026, 10:40 a. m.
Reportado por	Docente del Departamento de Informática.
Servicio afectado	Aula virtual Moodle - curso de Informática.
Descripción	Usuario de otro departamento visualiza un enlace inesperado.
Impacto conocido	Acceso indebido posible; por confirmar.
Medida inicial	Se restringe la configuración afectada tras validación.
Responsable y seguimiento	Persona técnica asignada; revisión pendiente.

Cómo comunicar un incidente

- Explicar qué servicio está afectado y qué puede hacer la persona usuaria mientras se investiga.
- Evitar compartir nombres, contraseñas, expedientes o capturas con datos sensibles en chats abiertos.
- Actualizar el estado cuando se tenga información confirmada.

> **REDACCIÓN CLARA**
> En lugar de escribir “el servidor falló por un hacker”, registrar “se detectó una sesión no reconocida; la causa está en investigación”.

9 Prevención, práctica y glosario

Después de atender el incidente, el trabajo continúa: se revisa por qué pudo ocurrir y qué controles pueden reducir la probabilidad de repetición.

Checklist de prevención

- ☐ Las cuentas tienen contraseñas únicas y MFA cuando corresponde.
- ☐ Los cursos Moodle mantienen participantes, cohortes y permisos revisados.
- ☐ Se prueban respaldos y la restauración en un entorno aislado.
- ☐ Las actualizaciones y el estado del almacenamiento se revisan con regularidad.
- ☐ Las personas conocen un canal sencillo para reportar incidentes.

Tres ejercicios para capacitación

CASO	PREGUNTA PARA DISCUTIR
Correo falso de Moodle	¿Qué datos guardamos para reportar y qué no debemos hacer?
Equipo con archivos cifrados	¿Qué acciones iniciales reducen el riesgo de propagación?
Acceso a PDF de otro curso	¿Cómo comprobamos y corregimos el permiso?

Glosario breve

Incidente: suceso que afecta o amenaza la seguridad. **Contención:** medidas para limitar el daño. **Evidencia:** información útil para revisar los hechos. **Restauración:** recuperación de datos o servicios a partir de una copia válida.

Referencias de consulta

• NIST — Computer Security Incident Handling Guide (SP 800-61), y materiales complementarios en www.nist.gov.

• CISA — Recursos de respuesta y seguridad digital: www.cisa.gov.

Documento formativo del proyecto académico CTCR. No reemplaza un plan institucional de respuesta a incidentes.